Phishing Email Detection & Awareness Systems Report

Prepared by: Phenyo Pege

Cyber Security Task 2

Contents

1. Executive Summary 2
2. Scope, Method and Sources 2
3. Risk Classifications Guide 3
4. Results 3
6. Prevention & Awareness Guidelines 7
7. Employee Do's and Don'ts 7
8. What to Do If You Clicked or Replied 8
9. Limitations & Ethics 8
Sources and Credits 9
Evidence 9

1. Executive Summary

A lot of the times, phishing happens and succeeds mainly because people cannot tell the difference between a fake email and a real one. This report looks at five real emails that are taken from a research collection and classifies each one a being either **safe, suspicious and phishing.**

Result	Count
Safe	1
Suspicious	2
Phishing	2

2. Scope, Method and Sources

All samples come from the public Phishing Pot collection done by rf-piexoto (https://github.com/rf-peixoto/phishing_pot) which is a library of real emails gathered by honeypot mailboxes for researchers and is a licensed collection CC BY-NC 4.0.

Method (7 Steps)

- Collect five samples
- Analyse the headers
- Inspect the headers
- Identify phishing indicators
- Classify each email
- Document the findings
- Write a prevention and awareness guidance

3. Risk Classifications Guide

CLASS	MEANING	WHAT READERS SHOULD DO
Safe	The sender is verified, nothing unusual is requested and the reader is not promoted to provide unnecessary information	Normal Use
Suspicious	This can be some warning signs like the email consisting of exaggerated claims but a clear attempt to steal credentials or impersonate a brand	The email can be reported as spam or deleted. So it is not be clicked
Phishing	There is a clear attempt to deceive, there is impersonation of a trusted brand that usually pushes the reader to click links and hand over their information	Ideally the reader should report or share the email to IT and the block and delete

4. Results

EMAIL 1: SAFE: Github release notification

All the three technical checks pass and the content matches the sender

Source: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-296.eml

CHECK	FINDING	MEANING
From	Notification@github.com	GitHub can send notices on behalf of users
SPF	Pass	Server is authorised to send for GitHub
DKIM	Pass	The email was not altered and signed by GitHub
DMARC	Pass	Sender domain and checks line up
Tone of the email	Informational, no request for password or any payments	No pressuring the reader

EMAIL 2: SUSPICIOUS

Mismatched reply-to, link to an unknown site and unrelated domains

Source: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-250.eml

CHECK	FINDING	MEANING
From	‘’Dr Mark Vance’ with an address at jwgmedia.com	GitHub can send notices on behalf of users
SPF, DKIM & DMARC	Pass	Authentic but does not mean the content is honest
Reply To	An address at brendamurphyrealestate.com	Replies are sent to a different an unrelated domain
Tone and Content	Promises a result of 3.8 inches in 12 days and urges reader to watch a presentation	Unproven claims

EMAIL 3: SUSPICIOUS

There is a failed SPF and DKIM and a disposable sender account

Source: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-89.eml

CHECK	FINDING	MEANING
From	Throwaway address on a cloudmatrixtech.onmicrosoft.com account	Not a real gambling brand
SPF	Fail	Server is not authorised
DKIM	Fail	The message's signature is invalid
DMARC	None	No policy protects the sender
Tone of the email	The email creates pressure '47 mins left'	Artificial Urgency

EMAIL 4: PHISHING

Fake look alike domain, mismatched sender, suspicious links and brand impersonation

Source: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-2.eml

CHECK	FINDING	MEANING
From	'Microsoft account team' at no-reply@accessaccsecurity.com	The domain is not microsoft.com but looks official
SPF	None	Sender domain is not authorised
DKIM	None	Nothing proves who sent the email
DMARC	Error	No usable policy
Tone of the email	Informational, no request for password or any payments	Fear tactic used

EMAIL 5: PHISHING

Brand mismatch, hidden redirect to cloud storage, urgency

Source: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-283.eml

CHECK	FINDING	MEANING
From	'no-reply' at support@vantagemarkets.com	An online trading company that's not Apple
SPF / DKIM	Pass	Authentication alone cannot expose the scam
DMARC	Error	Sender policy is misconfigured
Tone of the email	Pressures the reader. 'Immediately, expires in 24 hours'	Fear tactic used, as well as urgency

5. Common Phishing Indicators

Indicator	Seen in
Fake or look-alike sender domain	Email 4, Email 5
Sender, Return-Path and Reply-To do not match	Emails 2, 4
Failed or missing SPF / DKIM / DMARC	Emails 3, 4
Urgency or fear ("immediately", "24 hours", "47 mins left")	Emails 3, 4, 5
Suspicious or hidden link destination	Emails 2, 3, 4, 5
Generic greeting or no personal detail	Emails 4, 5
Brand pretended by the wrong company	Emails 4, 5
Hidden filler text to evade spam filters	Emails 3, 4

6. Prevention & Awareness Guidelines

1. Check the actual address: Display names lie (anyone can write "Microsoft"). Always check the email domain after @.
2. Beware of urgency: Real companies rarely demand action within hours under threat of account loss or deletion.
3. Hover before clicking: Inspect where the URL actually points. If it doesn't match the company's real website, don't click.
4. Navigate independently: Type the website address manually into your browser, use a saved bookmark, or use the official app to check your account.
5. Technical checks aren't proof of safety: Email security passes only verify who sent the message, not whether their intentions are honest.
6. Protect sensitive data: Never send passwords, one-time security codes, or payment info over email. Real support teams never request your codes.
7. Enable Multi-Factor Authentication (MFA): Adding MFA prevents attackers from accessing your account using only a stolen password.
8. Update software & use a password manager: Keep your browser/software updated. Password managers won't auto-fill credentials on fake sites.
9. Report and delete: Use your email provider's "Report Phishing" option or notify your IT/security team, then delete the email.
10.

7. Employee Do's and Don'ts

Do	Don't
Pause and carefully review the sender's full address	Click links or buttons in unexpected emails
Go directly to the official website yourself	Reply to the email or call phone numbers written inside it
Report suspicious messages to IT or your security team	Open unexpected attachments
Use unique passwords alongside multi-factor authentication	Enter your password after following a link from an email

Ask a colleague or your IT team if you're uncertain	Forward the suspicious email to coworkers
Delete the message after reporting it	Assume an email is safe just because it looks professional

8. What to Do If You Clicked or Replied

1. Stop instantly: Do not enter any more information or click further.
2. Report immediately: Notify IT/security right away—acting fast is far more important than feeling embarrassed.
3. Change compromised passwords: If you entered a password, change it immediately from a safe device and log out of all active sessions.
4. Audit account & financial activity: Inspect your account for unknown sign-in history or unauthorized forwarding rules. Monitor your bank/card statements if financial info was exposed.

9. Limitations & Ethics

- Sample scope: Five samples provide a basic demonstration, not a complete picture of every security threat.
- Header data context: Email header analysis shows only what the receiving server captured upon delivery.
- Link handling: Links were inspected purely as plain text and none were clicked, and destinations were pulled from the raw message source without live testing.
- Data handling: All sample emails are public, fully anonymized, used strictly for educational purposes, and linked to their original sources rather than republishing raw body text here.

Sources and Credits

- Phishing Pot (rf-peixoto): GitHub Repository (CC BY-NC 4.0).
  - Used samples #2, #89, #250, #283, and #296.
- Task Guidelines: Future Interns Cybersecurity Task 2 (2026).
- Header Analyzers:
  - Google Admin Toolbox Messageheader
  - MXToolbox Email Headers.

Evidence

Header starts for each email are in a repository folder (Evidence folder)